



Ghrab

VOC – VULNERABILITY OPERATIONS CENTER

An operations center that thinks in attack paths, not findings.

An autonomous, agent-driven platform that reads raw scan results and our own infrastructure, then discovers — on its own — the multi-step routes an attacker could take from the internet to our most critical systems. Every claim it makes is checked against reality before anyone sees it.

6/6

documented attack paths
rediscovered
autonomously — on both
test environments

7

specialized AI agents
working as one security
team

100%

of AI claims verified
against ground truth
before display

3

AI providers with
automatic failover — no
single outage stops us

01 • THE PROBLEM

Attackers chain findings. Dashboards show rows.

A vulnerability scanner produces thousands of isolated findings, and humans triage them one by one, by severity score. But a real attacker never exploits a single finding — they **chain several “medium” findings across machines**. A pile of individually-mediocre issues can hide one catastrophic route. Tools that review findings in a table cannot see that route.

TRADITIONAL TOOLS SEE

Rows in a table

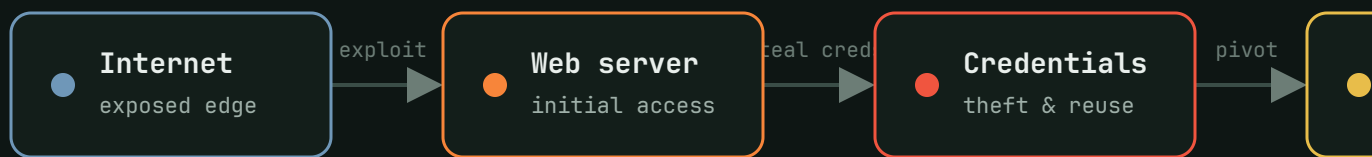
Rank by CVSS (CVSS = the standard 0–10 severity score), patch the reds, ignore the yellows. Each finding is judged alone — the relationships between them are invisible.

GHRAB SEES

Paths across machines

It connects findings into the actual routes an adversary could walk — internet foothold to crown jewel (crown jewel = our most business-critical system) — and ranks them by how much damage each route enables.

A SINGLE ATTACK PATH, IN FIVE HOPS



Each hop on its own might be a “medium.” Together they form a direct line to the target — which is exactly the kind of route Ghrab is built to surface.

From a script to a security team

“AI agent” is an overused phrase, so here is the plain-language ladder — each rung adds one capability the one below it lacks. Ghrab sits on the top rung.

Scripts & rules

Fixed logic. Brittle.
Finds only what it was told to.

A single AI call

A smart one-shot answer.
No memory, no tools, no check —
and prone to making things up.

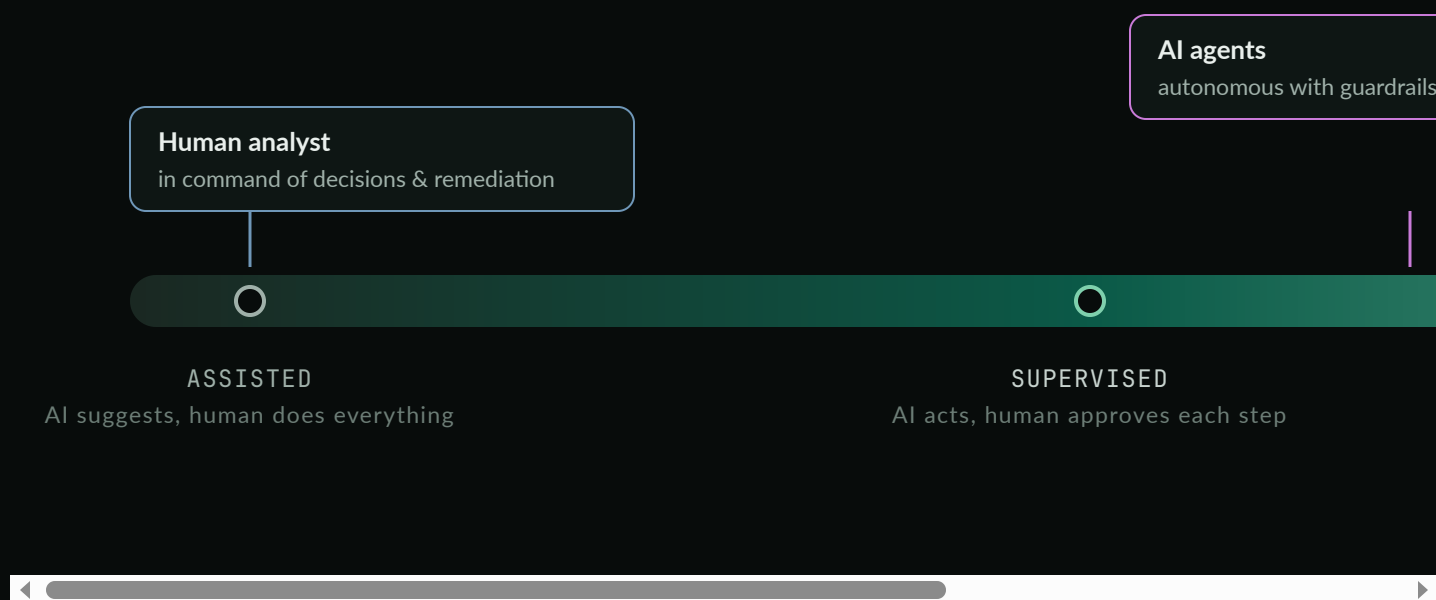
An AI agent

A model given a role,
grounded context, and
memory.
Reasons in steps, uses
tools, and its output is checked
against reality before anyone



Autonomy where it's safe, human judgment where it matters

Not everything should run on its own. Ghrab places each part of the system deliberately on the autonomy spectrum — and keeps the analyst in command of the decisions that carry consequences.



Seven specialists, one investigation

Each agent has a narrow job, a source of grounded truth it works from, and a check that confirms its output. They run in sequence, so each one builds on verified work — not guesses — from the one before.

Analyst Detection Agent FLAGSHIP

Given *only* the infrastructure grounding and a plain classification of what each finding lets an attacker do — no hints, no pre-solved answers — it independently reasons out attack paths, hop by hop. Every hop is verified against real hosts and real finding IDs.

GROUNDED IN `infra map + capability classes`

VERIFIED BY `real hosts & finding IDs`

Discovery Agent

Validates, ranks and narrates the candidate chains the graph engine finds — and hunts for “toxic combinations” of findings that are dangerous only together.

grounded in deterministic chains
verified by `finding IDs`

Correlation Agent

Cross-references the full asset inventory against every finding to surface non-obvious risk, and re-prioritizes beyond the raw severity score.

grounded in asset inventory + findings
verified by `host references`

Compliance Agent

Maps findings and attack paths onto compliance and regulatory impact, so a technical route becomes an audit-relevant statement.

grounded in findings + paths
verified by `control mapping`

Triage Agent

Reads the conclusions of every prior agent and writes one consistent executive synthesis — the narrative on the Command Center.

grounded in all agent outputs
verified by `consistency check`

Remediation Agent

Turns paths into concrete, ordered fix plans — surfacing the single fix that severs the most attack paths at once.

grounded in the attack graph
verified by `path coverage`

Grounded AI Analyst `chat`

A streaming conversational analyst that answers questions by citing real discovered paths and real finding IDs — never generic advice.

grounded in discovered paths
verified by `cited path / finding IDs`

05 • THE PIPELINE CYCLE

Math first, AI second, verified before you see it

This is the heart of the platform. A deterministic engine builds a verified map with no AI at all; the agents then reason over that map; and a verification gate stands between the AI and the screen. The two layers below are drawn deliberately distinct.

INPUTS

Scan export

CSV findings — QID, CVSS, hosts

Architecture / CMDB doc

zones, assets, trust, credential reuse

1 · Ingest

Raw scan export, the architecture doc and threat-intel signals all arrive together.

2 · Ground

A CMDB engine parses the doc into zones, assets, criticality & reachability rules.

3 · Analyze

NO AI · ALWAYS RUNS

Capability classifier + reachability graph maps every internet→jewel chain by blast radius.

DETERMINISTIC LAYER

The cycle repeats — findings re-ingest

QID = the scanner's ID for a finding · CMDB = the inventory of our systems · EPSS = the probability a vulnerability is exploited in the wild · KEV = the public catalog of known-exploited vulnerabilities.

The deterministic layer is pure graph theory: reproducible, explainable, and impossible to hallucinate.

The AI can't make things up and reach the screen

The single biggest concern with AI is confident invention. Four design choices, working together, make that structurally hard here — and we measure the result publicly rather than asking you to take our word.

01

Deterministic first

The AI never invents the map. It reasons over a map the math already built and proved.

02

The answer key is locked away

Documented paths are held completely outside the pipeline — like an exam key in a drawer. The agents can't cheat; they're scored against it afterward.

03

Post-generation verification

Every cited path, finding and host is re-checked against ground truth. Anything unverifiable is filtered or flagged before the UI.

04

The score is public

A Verification page in the product shows how the AI scores against the held-out oracle — honestly, in the open.

6 / 6

documented attack paths the deterministic engine rediscovers — on *both* test environments.

6

grounded paths the Analyst Agent found *independently*, all hitting the real crown-jewel systems.

0

unverifiable references allowed to reach the screen.

No single AI vendor can take us down

The platform runs across three independent AI providers with automatic failover, paced to each provider's limits and retried with backoff. If one has an outage, analysis continues.

Mistral · Groq · Gemini

Three providers behind one interface. If a request fails, it fails over to the next automatically.

Rate-limit pacing

Calls are paced per provider so we stay within limits instead of hammering into errors.

Retry with backoff

Transient failures are retried with increasing waits — a hiccup never becomes a stall.

Machine speed against a machine adversary

Attackers already automate the chaining of findings. A defense that reviews findings one at a time is structurally outmatched. Ghrab thinks in chains, continuously, and explains itself in plain language — so we act on routes, not rows.

From noise to routes

Thousands of findings become a ranked, short list of real attack paths.

The one fix that matters

See the single remediation that severs the most attack paths, first.

Audit-ready mapping

Findings and paths tied to compliance impact, ready for review.

An analyst on call

A grounded chat answers questions instantly, citing real evidence.

WHAT'S IN THE LIVE PLATFORM TODAY

Command Center

Findings explorer

Attack Paths graph

Teams

Correlation

Compliance

Grounded AI Analyst chat

Verification page

Back the production rollout

Ghrab VOC works today and proves itself against a held-out answer key. To run it as core infrastructure, I'm asking for support to harden it for production and connect it to more of our data.

Production hardening

Postgres, Redis, background job workers, single sign-on (OIDC), and a centralized LLM gateway — the plumbing that makes it enterprise-grade.

Continuous re-scans

Scheduled, automatic re-analysis so the attack-path picture stays current between manual reviews.

More data connectors

Direct feeds from more scanners and inventory sources, so coverage grows without manual exports.



Ghrab VOC — Vulnerability Operations Center

An autonomous, agent-driven operations center that thinks in attack paths, not findings.

غراب • the raven